Datenschutz bei der Nutzung von KI

KI IN DER WIRTSCHAFTSPRÜFUNG

01 **Ausgangslage**

02 Rechtlicher Rahmen

03 Praxis: Tools und Führung

04 Lösungsvorschlag und Fazit



Abschnitt 1 von 4

Ausgangslage

Fall Revisio AG: Drei KI-Abos, aber keine Regeln

Revisio AG: KMU-Revisionsunternehmen mit 8 Mitarbeitenden und rund 80 eingeschränkten Revisionen. Die KI wird nur in Revisionsmandaten genutzt, also im regulierten Bereich mit Berufsgeheimnis.

ChatGPT Plus

Privates Abo

Wer
Mitarbeiter A hat das Abo privat abgeschlossen und rechnet es über die Spesen ab.

Wofür
Saldenlisten und Hauptbuch-Exporte geprüfter Gesellschaften hochladen und Auffälligkeiten suchen lassen

Claude Pro

Privates Abo

Wer
Mitarbeiterin B nutzt ihr eigenes Konto mit privater E-Mail-Adresse.

Wofür
Management Letter mit Mandantennamen entwerfen, Verträge des Prüfkunden zusammenfassen

Microsoft 365 Copilot

Firmenlizenz

Wer
Die Firma hat die Lizenz für ihren eigenen Microsoft-365-Tenant gekauft.

Wofür
VR-Protokolle geprüfter Gesellschaften auswerten; die Websuche ist eingeschaltet

Daten Websuche - copilot über Web über bing eine Anfrage starten darf!

Bisher: keine KI-Weisung, keine Übersicht über die genutzten Tools, Mandanten nicht informiert.

nur bei WP eingesetzt! im Beispiel

Fiktiver Fall

Vier Fragen an Sie: Austausch mit den Tischnachbarn (10 Minuten)

1 Datenschutz

Dürfen die Mitarbeitenden Personendaten aus den Prüfungsunterlagen, z.B. Namen in VR-Protokollen und Saldenlisten, in die drei Tools eingeben?

2 Berufsgeheimnis

Verletzt die Revisio AG das Berufsgeheimnis, wenn sie Saldenlisten oder VR-Protokolle hochlädt?

3 Schatten-IT

Welche Risiken entstehen durch die privat abgeschlossenen Abos, und wie erfährt die Führung davon?

4 Führung

Was muss die Geschäftsleitung regeln, damit die Mitarbeitenden KI zulässig nutzen können?

Notieren Sie Ihre Antworten. Die Lösungsvorschläge folgen nach dem Theorieteil.

Datenschutz bei der Nutzung von KI

KI IN DER WIRTSCHAFTSPRÜFUNG

01 Ausgangslage

02 Rechtlicher Rahmen

03 Praxis: Tools und Führung

04 Lösungsvorschlag und Fazit



Abschnitt 2 von 4

Rechtlicher Rahmen

Das Berufsgeheimnis geht weiter als der Datenschutz

Datenschutz (DSG)

Schützt

Personendaten natürlicher Personen in den Prüfungsunterlagen, z.B. VR-Mitglieder, Debitoren, Mitarbeitende des Prüfkunden

Bei der KI-Nutzung

- **Auftragsbearbeitung nur mit Vertrag (DPA/AVV[1]) und Datensicherheit** (Art. 9 DSG)
- **Bekanntgabe ins Ausland** nur bei angemessenem Schutz, z.B. zertifizierter US-Anbieter (Art. 16 DSG)
- **Technische und organisatorische Massnahmen** (Art. 8 DSG)

Sanktion: Busse bis CHF 250'000 gegen die verantwortliche Person (Art. 61 DSG)

Berufsgeheimnis

Schützt

Alle im Mandat bekannt gewordenen Sachverhalte, auch Geschäftsgeheimnisse von Gesellschaften (HWP ER Rz 10)

Bei der KI-Nutzung

- **Revisionsgeheimnis** (Art. 730b Abs. 2 OR, Art. 321 StGB)
- **Anbieter als Hilfsperson:** möglich, wenn er vertraglich ans Berufsgeheimnis gebunden ist und nur auf Weisung arbeitet (Art. 321 Ziff. 1 StGB, vgl. Folie 58)
- **Sonst nur mit schriftlicher Entbindung** durch den Mandanten (HWP ER Rz 10)
- **Ein DPA/AVV allein genügt nicht**: Vertragsergänzung zum Berufsgeheimnis nötig (Vischer)

Sanktion: Freiheitsstrafe bis 3 Jahre oder Geldstrafe (Art. 321 StGB)

Faustregel: Was für das DSG genügt, genügt für das Berufsgeheimnis noch nicht.

[1] DPA/AVV: Auftragsbearbeitungsvertrag (Art. 9 DSG), engl. Data Processing Agreement (DPA)
Quelle: Art. 8, 9, 16, 61 DSG; Art. 730b Abs. 2 OR; Art. 321 StGB; HWP ER 2026, Teil II, Rz 10; VISCHER, Popular AI Tools: What about data protection?, Stand 8. Juli 2026

KI ist zulässig, solange der Anbieter Hilfsperson bleibt

Rechtsgrundlage: Art. 321 StGB
Ziff. 1: Das Berufsgeheimnis gilt für Revisoren «sowie ihre Hilfspersonen». **Ziff. 2:** Straflos mit Einwilligung des Berechtigten.

Abhängigkeiten: Wann der KI-Anbieter als Hilfsperson gilt[1]

Revisionsstelle
Geheimnisträger, erteilt die Weisung

➡

KI-Anbieter als Hilfsperson
Input verarbeiten, Output zurück, sonst nichts

➡

Kein «unberechtigter Dritter»
Berufsgeheimnis nicht verletzt

Vertraglich gebunden: DPA/AVV plus Zusatzklausel für alle Mandatsinformationen; er allein schützt nur Personendaten

Tatsächlich eingehalten: Der Anbieter nutzt die Daten nur für den vereinbarten Zweck

Zwei Stolpersteine in den Nutzungsbedingungen machen den Anbieter zum Dritten

Modell-Training: Nutzt er Inputs für eigene Modelle, handelt er für eigene Zwecke

Abuse Monitoring: Mitarbeitende des Anbieters sehen Inhalte; Opt-out schwieriger als beim Training

Lösung: Enterprise-Variante mit No-Training- und No-Monitoring-Commitment. **Sonst:** nur mit spezifischer Einwilligung des Mandanten; «wir setzen KI ein» schützt kaum.

Rechtslage unklar: Ob KI-Anbieter als Hilfspersonen von Revisoren gelten, ist nicht geklärt. Die Rechtskommission von EXPERTsuisse prüft die Frage; ihre hoffentlich baldige Verlautbarung abwarten.

[1] Dr. David Schneeberger, Berufsgeheimnis und KI, www.schneeberger.legal/post/berufsgeheimnis-ki-anwalt (abgerufen 22.10.2026); Quelle: Art. 321 StGB

Datenschutz bei der Nutzung von KI

KI IN DER WIRTSCHAFTSPRÜFUNG

01 Ausgangslage

02 Rechtlicher Rahmen

03 Praxis: Tools und Führung

04 Lösungsvorschlag und Fazit



Abschnitt 3 von 4

Praxis: Tools und Führung

Mandantendaten gehören nur in Firmenversionen mit den nötigen Verträgen

Tool	DPA/AVV	Personendaten	Vertrauliche Daten	Berufsgeheimnis	Training durch Anbieter
Claude Pro *privates Abo, im Fall*	Nein	Nein	Nein	**Nein**	Ja
Claude Team / Enterprise *Firmenversion*	Ja	Mit Vorbehalt[2]	Möglich	**Nein**	Nein
Microsoft 365 Copilot *Firmenlizenz, im Fall*	Ja	Ohne Websuche[1]	Ohne Websuche[1]	**Nur mit Vertragsergänzung, ohne Websuche und Anthropic-Modelle**	Nein
ChatGPT Plus *privates Abo, im Fall*	Nein	Nein	Nein	**Nein**	Ja
ChatGPT Team / Enterprise *Firmenversion*	Ja, separat	Mit Vorbehalt[2]	Möglich	**Nein**	Nein

Mindestanforderungen erfüllt | nur mit Vorbehalt oder Zusatzmassnahmen | nicht erfüllt

Stand 8. Juli 2026: Was heute gilt, kann morgen schon nicht mehr sein. Bedingungen vor dem Einsatz neu prüfen.

[1] Mit Websuche (Bing) gelten die Bedingungen für Privatkunden. [2] Der DPA/AVV deckt keine besonders schützenswerten Personendaten ab; Risikobeurteilung nötig. Gleiche Ampel auch für ChatGPT Pro, Claude Max und Copilot Pro (privat). Stand der Bedingungen 8. Juli 2026; diese ändern sich laufend.
Quelle: VISCHER, Popular AI Tools: What about data protection? (Hunger/Baeriswyl), Stand 8. Juli 2026

Drei erprobte Wege, wie Ihre Daten geschützt bleiben – je nach gewünschter Kontrolle

1 Hyperscaler mit Datenschutz-«Garantie»

z. B. Microsoft 365 Copilot

Cloud-Dienste grosser Anbieter («Hyperscaler») mit Enterprise-Datenschutz. Ihre Daten bleiben in Ihrem eigenen Bereich («Tenant»), sind verschlüsselt und werden nicht zum Training der KI verwendet.

Schnell startklar, kein eigener Aufbau – Datenschutz ist vertraglich zugesichert.

2 Eigenes lokales Tool mit Claude (Cowork)

lokal auf Ihrem Rechner

Sie bauen mit Claude ein Werkzeug direkt auf Ihrem Rechner. Echte Daten fliessen nur dorthin – lokal. Fürs gemeinsame Aufbauen braucht es Beispieldaten; diese anonymisieren Sie vorab.

Volle Datenhoheit, flexibel erweiterbar – Anonymisierung der Beispieldaten nötig.

3 Lokales Open-Source-Modell

«kleines Modell»

Ein frei verfügbares Sprachmodell (Open-Source-LLM) läuft komplett auf Ihren Unternehmensgeräten. Kein Internet, keine Cloud: Die Daten verlassen den Rechner/lokalen Server nie.

Volle Kontrolle und maximale Vertraulichkeit; dafür Einrichtungskosten und bescheidenere Leistung.

Das Tarnkappen-Prinzip
1 Echte Daten nehmen **2** Namen, Konten, Beträge durch Platzhalter ersetzen
3 Nur diese anonymen Beispieldaten zum Entwickeln nutzen

Up to date bleiben: David Rosenthal, LinkedIn-Beitrag zum Datenschutz.

Praxisbeispiel DataVision AG. Quelle: Fabian Meisser, DataVision AG, «KI mit DataVision», Handout September 2026

Schatten-IT: Was die Führung nicht kennt, kann sie nicht absichern

Was ist Schatten-IT?

IT-Tools, die Mitarbeitende ohne Wissen oder Freigabe der Führung für die Arbeit nutzen.

Typische Formen

- Private KI-Abos, bezahlt mit Kreditkarte oder über Spesen
- Gratisversionen im Browser
- Browser-Erweiterungen und Transkription von Sitzungen
- Belege mit dem privaten Handy fotografieren und hochladen

Warum das riskant ist

Kein Vertrag
Es gelten Privatkundenbedingungen: kein DPA/AVV, keine Geheimhaltung für Berufsgeheimnisse.

Daten für Eigenzwecke
Der Anbieter darf Eingaben für Training oder Serviceverbesserung nutzen.

Kein Zugriff der Firma
Das Konto gehört der Mitarbeiterin; Chats und Uploads bleiben auch nach dem Austritt dort.

Keine Steuerung im QM-System
Die Führung erkennt das Risiko nicht und kann keine Massnahme festlegen.

Verbieten allein reicht nicht: Die Firma muss eine geprüfte Lösung anbieten, sonst weichen die Mitarbeitenden auf private Abos aus.

Quelle: VISCHER, Popular AI Tools: What about data protection?, Stand 8. Juli 2026; HWP ER 2026, Teil II, Rz 97–98

Die Führung setzt den Rahmen mit fünf Massnahmen

1

KI-Weisung erlassen

Festlegen, welche Tools für welche Daten erlaubt sind; private Abos für Mandatsdaten verbieten.

2

Verträge prüfen

DPA/AVV abschliessen; für Berufsgeheimnisse eine Ergänzung zur Geheimhaltung mit dem Anbieter vereinbaren.

3

Tools konfigurieren

Nur Firmenkonten; Training und Websuche ausschalten, Zugriffe berechtigen (HWP ER Rz 98). Drei Wege: Folie 61.

4

Mandanten einbinden

KI-Einsatz in den Auftrags-bedingungen regeln oder schriftlich entbinden lassen (HWP ER Rz 10, 124).

5

Schulen und überwachen

Mitarbeitende schulen, Einhaltung in der Nachschau prüfen, Bedingungen der Anbieter jährlich prüfen.

Im QM-System festhalten: KI-Nutzung als Risiko in die Risiko-Kontroll-Matrix aufnehmen (ISQM-CH 1).

Quelle: HWP ER 2026, Teil II, Rz 10, 97–98, 103, 124; VISCHER, Popular AI Tools: What about data protection?, Stand 8. Juli 2026; Meisser, DataVision AG, 2026

Bevor Daten in die KI fliessen: klare Leitplanken, was wohin darf

Branchenfremdes, illustratives Beispiel, keine Empfehlung

Nr	Vorgang / Inhalt		MS Copilot	Claude (for Work)
1	**Interne Prozesse**	Buchungsrichtlinien, interne Abläufe, Best Practices, Präsentationen	OK	OK
2	**Interne Daten**	Budgets, Kostenstellen, Löhne/Honorare (intern)	OK	nach Abwägung
3	**Technische Vorlagen & Tools**	Excel-Formeln & -Vorlagen, Makros, lokale Auswertungstools (ohne echte Daten)	OK	OK
4	**Auswertungen mit echten Daten**	Reports & Excel-Tabellen mit realen Finanz- und Umsatzzahlen	OK	Nein *
5	**Externe, öffentlich zugängliche Daten**	Firmennamen, öffentliche Geschäftsberichte, Marktpreise	OK	OK
6	**Externe, wenig kritische Daten**	Welches ERP ein Partner nutzt, Standard-Zahlungskonditionen	OK	nach Abwägung
7	**Externe, businessrelevante Daten**	Einkaufspreise, Margen, Kalkulationen, Lieferantenkonditionen	OK	Nein *
8	**Externe Personendaten**	Kunden-/Lieferantenkontakte, Mitarbeitende mit HR-Stammdaten	OK	Nein *
9	**Bes. schützenswerte Personendaten (DSG)**	Gesundheitsdaten, Lohnpfändungen / Betreibungen	Nein	Nein
10	**Passwörter / Keys**	ERP-, E-Banking- & Portal-Logins, API-Keys	Nein	Nein

* Nein bezogen auf echte, schützenswerte Daten.
Quelle: Fabian Meisser, DataVision AG, «KI mit DataVision», Handout September 2026

Datenschutz bei der Nutzung von KI

KI IN DER WIRTSCHAFTSPRÜFUNG

01 Ausgangslage

02 Rechtlicher Rahmen

03 Praxis: Tools und Führung

04 Lösungsvorschlag und Fazit



Abschnitt 4 von 4

Lösungsvorschlag und Fazit

Lösungsvorschlag: Private KI-Abos sind für Mandantendaten tabu

1 Datenschutz

ChatGPT Plus und Claude Pro: nein, es fehlt ein DPA/AVV und der Anbieter darf die Daten fürs Training nutzen. Copilot: ja, dank DPA/AVV, aber nur ohne Websuche; im Fall ist sie eingeschaltet.

2 Berufsgeheimnis

Ja, Berufsgeheimnis wird verletzt.
Strafe: bis 3 Jahre Freiheitsstrafe oder Geldstrafe (Art. 321 StGB).

3 Schatten-IT

Massive Risiken, wenn nichts erlaubt wird, weil die Leute es trotzdem anwenden. Spesenkontrolle könnte immerhin Mitarbeiter A identifizieren.

4 Führung

KI-Weisung erlassen, private Abos für Mandatsdaten verbieten, in Copilot Websuche und Anthropic-Modelle abschalten, Vertrag ergänzen, Auftragsbedingungen anpassen, schulen.

Quelle: Fiktiver Fall; VISCHER, Popular AI Tools, Stand 8. Juli 2026; HWP ER 2026, Teil II, Rz 10, 124; Art. 9, 16 DSG; Art. 730b Abs. 2 OR; Art. 321 StGB

Fazit

01	**Vorsicht mit Mandantendaten:** Private KI-Abos haben keinen DPA/AVV, und der Anbieter darf die Eingaben für eigene Zwecke nutzen.
02	**Nutzungsbestimmungen kennen:** DPA/AVV, Training, Websuche und Geheimhaltung entscheiden, nicht der Name des Tools. Was heute gilt, kann morgen schon nicht mehr sein.
03	**Das Berufsgeheimnis geht weiter:** Auch Firmenversionen brauchen dafür eine Vertragsergänzung oder die schriftliche Entbindung durch den Mandanten.
04	**Schatten-IT ernst nehmen:** Wer keine geprüfte Firmenlösung anbietet, treibt die Mitarbeitenden in private Abos.
05	**Die Führung setzt den Rahmen:** KI-Weisung, Konfiguration, Auftragsbedingungen und Schulung im QM-System verankern. Die erwartete Verlautbarung der EXPERTsuisse-Rechtskommission verfolgen.

Haben Sie Fragen?

